

I. REQUEST

1. The President of the Committee on Constitutional Affairs, Rights, Freedoms, and Guarantees requested the National Data Protection Commission (CNPd) to issue an opinion on the "Draft Law No. 50/XVI/1st (GOV) - Authorizes the Government to transpose Directive (EU) 2022/2555, concerning measures aimed at ensuring a high common level of cybersecurity in the Union.
2. The request made and this Opinion fall within the attributions and competencies of the CNPD, as an independent administrative entity with authority to oversee the processing of personal data, conferred by paragraph c) of number 1 of article 57, combined with paragraph b) of number 3 of article 58, and with number 4 of article 36, all of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016 (General Data Protection Regulation - GDPR), in conjunction with the provisions of article 3, number 2 of article 4, and paragraph a) of number 1 of article 6, all of Law No. 58/2019, of August 8, which implements the GDPR in the internal legal order.

II. ANALYSIS

3. The present request for a pronouncement essentially concerns the transposition of Directive (EU) 2022/2555 of the European Parliament and of the Council, of December 14, aimed at ensuring a high common level of cybersecurity throughout the European Union.
4. In this context, it is also proposed to implement in the internal legal order the obligations arising from Regulation (EU) 2019/881, of the European Parliament and of the Council, of April 17, concerning ENISA (European Union Agency for Cybersecurity) and the certification of cybersecurity of information and communication technologies, which repeals Regulation (EU) No. 526/2013 (Cybersecurity Regulation), implementing a national cybersecurity certification framework, as well as proceeding with the ninth amendment of the Internal Security Law, approved by Law No. 53/2008, of August 29, amended by Law No. 59/2015, of June 24, by Decree-Law No. 49/2017, of May 24, by Laws No. 21/2019, of February 25, and 73/2021, of November 12, by Decree-Law No. 122/2021, of December 30, by Law No. 24/2022, of December 16, and by Decree-Laws No. 41/2023, of June 2, and No. 99-A/2023, of October 27, to the second amendment of the Cybercrime Law, approved by Law No. 109/2009, of September 15, amended by Law No. 79/2021, of November 24, and also to the second amendment to the Electronic Communications Law, approved by Law No. 16/2022, of August 16, amended by Decree-Law No. 114/2024, of December 20.
5. This Commission has already had the opportunity to express its opinion on this Draft Law, this time at the request of the Secretary of State for the Presidency of the Council of Ministers, having returned the respective opinion within the timeframe requested for that purpose.
6. Upon reviewing the documentation now subject to the CNPD's judgment within the scope of its competencies, it is found that the legislative draft appears identical to that already analyzed regarding personal data protection, which gave rise to OPINION/2025/26, of February 27.
7. Therefore, since no new issues arise that require a qualitative change in the position taken by this Authority, the same analyses expressed in that document will be maintained, materialized in the following terms.

A. GENERAL CONSIDERATIONS ON THE DRAFT.

8. The CNPD considers it particularly important to pay attention to the Directive proposed for transposition, sharing the inspiring intention of this document, in the sense of seeking to ensure safeguards regarding the security risks that digitalization brings, as well as, in the same vein, the strengthening of the fundamental rights of citizens who are exposed to them.
9. In this regard, the provisions contained in the Directive to strengthen security measures and assess those risks, as well as their supervision and practical effectiveness, present themselves as positive concrete elements for the protection of citizens' fundamental rights, where the right to personal data protection is also included, a fundamental matrix that justifies it.
10. The same applies to say that the demands to combat cybercrime and the strengthening of enhanced cybersecurity measures cannot disregard having as their main addressee the subjective

rights of citizens and their personal and informational self-determination.

11. From this, it also follows that any legislative block that may be considered in this matter should not lose sight of the personal data protection legislation that precedes it and that should help to guarantee, and not the opposite, i.e., that in the unilateral or emphasized pursuit of certain security ends, it may indirectly stifle or hinder what in some way propelled it, such as a potential limitation or disrespect for the right to data protection.

12. Therefore, legislative work should be careful in balancing values, interests, and rights, and any limitation must take into account what is prescribed in article 52 of the Charter of Fundamental Rights of the European Union regarding possible restrictions on fundamental rights, keeping in mind that the right to personal data protection is provided for in article 8 of the same Charter.

PAR/2025/25

13. Article 52, paragraph 1, prescribes that “1. Any restriction on the exercise of the rights and freedoms recognized by this Charter must be provided for by law and respect the essential content of those rights and freedoms. In observance of the principle of proportionality, such restrictions may only be introduced if they are necessary and effectively correspond to objectives of general interest recognized by the Union, or to the need to protect the rights and freedoms of others.”

14. It has been the doctrine of the Court of Justice of the European Union (CJEU), in clarifying the application of the restrictive norm(s) that lawfully allow for a limiting interference with these rights, that the legal basis providing for such interference must clearly define the scope of that limitation, in dialectical confrontation, and be sufficiently clear and precise in that strict proportionality judgment, specifying the extent of the restriction on the exercise of the guaranteed right.

15. For such a limitation to be deemed justified in satisfying this requirement, the legislation must not only delineate the scope and application of the restriction in question but also, as a consequential reverse of the restriction, establish a set of core guarantees, so as to imperatively compartmentalize the breadth of the limitation, thus avoiding possibilities of abuse.

16. In fact, if limitation is the exception, the right cannot be genetically amputated, so there must, in learned terms, be a positive and negative delimitation of it, thus conferring its special identity, and allowing for the rational evaluative judgment of proportion, to be distributed through these elements.

17. Along this line, no diploma on this matter should affect the application of the rules provided for in the GDPR and other data protection legislation, with which it must engage in dialogue, and it must also ensure respect for the powers and responsibilities of the supervisory authorities on these matters, seeking a desirable and harmonious cooperation, with clear spaces of occupation, in order to share what is a common purpose. It is commendable, in this regard, the legislative care to provide in Article 1 of the Legal Regime of Cybersecurity, in subparagraphs c) and d), for the applicability of personal data protection legislation in an express manner.

18. The communion referred to can be read, from the outset, by observing the provisions of Article 5, paragraph 1 of the GDPR, which elevates security as one of the essential principles relating to data processing, and which is confirmed in Article 32 of the GDPR, which further develops it, demonstrating the importance that cybersecurity pursuits are essential to the rights and guarantees of citizens, to their personal reserve and information, as well as to their privacy.

19. It is, therefore, in this light that the points regarding data protection in this Bill will be analyzed, starting from the structuring presumption of the Directive of its full effectiveness, and that issues related to cybersecurity can only obtain satisfactory answers in a choice of regime that confirms and guarantees them, justifying any restriction only to the extent that it functionally serves them better, namely by observing strict principles of necessity and proportionality, in respect of the fundamental cores of personal rights, which are their key authorizing concepts.

20. Considering this,

B. ANALYSIS IN SPECIALITY: REGARDING ARTICLE 10 OF THE PROPOSAL.

21. Under the heading “Processing of personal data,” this article provides:

“Article 10

Processing of personal data

1 - Entities that are part of the institutional framework of cybersecurity, under the terms of Article 15,

process personal data to the extent strictly necessary to ensure compliance with legal obligations and the pursuit of missions of public interest or public authority in which they are invested, under the terms provided in subparagraphs c) or e) of paragraph 1 and in paragraph 3 of Article 6 of the GDPR and in accordance with this decree-law and other applicable national legislation.

See, in this regard, the content of Recital 14 of the Directive: This directive respects fundamental rights and observes the principles recognized in the Charter, namely the right to respect for private life and the private nature of communications, the right to the protection of personal data, the freedom of enterprise, the right to property, the right to action and to an impartial court, the presumption of innocence, and the rights of defense. The right to an effective remedy extends to the recipients of the services provided by essential and important entities. This directive shall be applied in accordance with these rights and principles.”

PAR/2025/25

2 - The entities that make up the institutional framework of cybersecurity may also process personal data for the pursuit of a legitimate interest of essential and important entities, as referred to in paragraph f), number 1 of Article 6 of the GDPR.

3 - Without prejudice to the provisions of Article 29 of Law No. 58/2019, of August 8, the entities that make up the institutional framework of cybersecurity may proceed with the processing of special categories of personal data to the extent strictly necessary:

4 - To prevent the consummation of a significant cyber threat to the security of networks and information systems;

5 - To effectively respond to a cybersecurity incident.

22. The reference made to Article 15 specifies which entities fulfill the plural institutional framework of cybersecurity, namely, the CSSC (as the advisory body to the Prime Minister in the field of cybersecurity), the CNSC (inter alia, as the national cybersecurity authority and cybersecurity certification authority), as well as, in the capacity of national sectoral or special cybersecurity authorities, the GNS, ANACOM, ASF, CMVM, Banco de Portugal, the Cybersecurity Security Assessment Commission, the Judicial Police, the SIS, the Strategic Information Service of Defense, and the Cyber Defense Operations Command.

23. In light of what has been stated in Part A., above, the indicative or declarative clause included in the number of the article under analysis appears, from the perspective of the CNPD, to be insufficient in relation to personal data protection legislation.

24. As this Commission has asserted, the mere inclusion of a generic clause regarding compliance with relevant legislation or the mere reference to data processing or compliance with the rules in force does not seem capable of fulfilling or satisfying the imperatives that the matter of data protection demands.

25. It is not ignored that, considering the essential object of the project under review and the activities that are intended to be imposed, there will be a need for the processing of personal data and, eventually, more or less evident adjustments with other interests at stake.

26. But it is important to recall that, assuming the legal dimension of fundamental rights, personal data and their protection form a crucial part of that core heritage of rights and freedoms on which the existence of a democratic society is based, with the consequences that such dignity demands, as one of its manifestations.

27. As a fundamental legal matter, the protection of personal data also enjoys the recognition of a set of specific principles, which emerge depending on the axiological dependence of that essential core, in the sense of confirming their efficiency, and imposes itself in a legally binding manner, and directly, on all Member States, as is the case, from the outset, of the GDPR and its norms.

28. This serves to say that when the Legislator declares that the conforming cores and the executing conditions of the norms it intends to construct will comply with the matter provided for in the GDPR and its Execution Law, it is not adding anything beyond the natural presumption of its legislative exercise, since, under penalty of illegality, no other solution could be conceived.

29. From this, it follows that when the Legislator is faced with regulation that involves the processing of personal data, the obligation that rests upon it will be to establish the particular regime of its conditions

that, on the one hand, demand the concretization of the rules provided in the imperative diplomas that regulate them, and that, on the other hand, consist of the substantiation or subsumption of the protection regime provided in the Constitution of the Portuguese Republic and in European and national legislation that shape this matter.

30. Only by outlining the subjects, foundations, purposes, and the modus by which the treatments will be executed and operationalized, specifically, will it be possible to conclude that those determinations and principles are fulfilled, which must result from a evaluative judgment of each proposed treatment, a consideration that, naturally and logically, arises from the prior ontology and design of the treatment that will then deserve - or not - that appropriate qualification.

31. If none of the terms of the treatment are defined, nothing can be concluded, nor can any judgment of proportionality be concretized.

32. Therefore, each time a specific processing of personal data is foreseen by emanating from normative contents, it must be regulated, in that same document, and with at least the same dignity, the specific imperatives capable of shaping the respective treatments in question and that concretize those same principles and their regime.

33. The specific regime of data processing, calling everything, is not a subsidiary or secondary or merely practical aspect; rather, it is where those fundamental rights are realized and addressed to citizens.

34. In its absence, it is not, therefore, possible for this Commission to express its value or disvalue, which sacrifices the attributions, intentions, and purposes of the Legislator when it foresees the prior opinion of this type of matters to this authority, which is not desirable.

3v.

PAR/2025/25

35. In light of this, vague references to the processing of personal data "(...) to the extent strictly necessary to ensure compliance with legal obligations and the pursuit of missions of public interest or public authority in which they are invested (...)" should be avoided, as it remains truly undefined which data is intended to be processed, what justifies that particular processing, for what purposes, and under what terms, elements that are essential to articulate a harmonious statement of necessity and proportionality that the Legislator claims to intend.

36. In general, whenever faced with data processing required to comply with the GDPR, it will also be necessary to specify the data retention period, their deletion, and the ontology of data and records to be designed, as well as their potential sharing method, namely the technical and organizational measures that should be applied to the processing, which also constitute unavoidable material aspects in data protection.

37. The absence of these conforming elements makes any preliminary assessment of guaranteeing citizens' rights impossible, constituting omissions that need to be addressed, starting with the realization of the principle of minimal intrusion into the sphere of data subjects.

38. The legal basis intended to be relied upon for such processing is also not indifferent, i.e., "...in accordance with the provisions of paragraphs c) or e) of paragraph 1 and paragraph 3 of Article 6 of the GDPR."

39. For personal data processing to occur lawfully, it must find support in one of the exhaustive statements provided in Article 6(1) of the GDPR: "a) The data subject has given consent to the processing of their personal data for one or more specific purposes; b) The processing is necessary for the performance of a contract to which the data subject is a party, or for taking steps at the request of the data subject prior to entering into a contract; c) The processing is necessary for compliance with a legal obligation to which the data controller is subject; d) The processing is necessary to protect the vital interests of the data subject or of another natural person; e) The processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller; f) The processing is necessary for the purposes of the legitimate interests pursued by the data controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, especially if the data subject is a child."

Note that the notion of personal data defined in the GDPR is very broad, and not all characterizing

elements are susceptible to signify the same degrees of intrusion: Personal data is understood as “information relating to an identified or identifiable natural person (‘data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person.”

5 On this matter, see Directive 2023/1 of this Commission.

4

1

PAR/2025/25

40. Although the European Legislator has expressed the possibility of cumulative grounds, these do not have the same nature and, likewise, do not share the same effects, nor do they always share the same requirements by their very nature.

41. Paragraph c) refers to the necessity of certain processing in view of compliance with a legal obligation to which the data controller is subject. According to paragraph 3 of the same article, it is further added that the obligation referred to must arise from Union law or the law of the Member State.

42. Such provision is essentially directed at data controllers, and to the extent that, as such, they are direct recipients of imperative normative commands that, in view of the need to comply with them, find themselves, to that same extent, under the obligation to process personal data in accordance with that command, it does not therefore constitute, in an extremely broad interpretation, an authorizing basis for promoting their own data processing.

43. Even if it is admitted that, in essence, this basis does not exclude public actors, there is no reason in the project that allows for a conclusion regarding its necessity or to assess that judgment.

44. However, a different matter is the basis established in what is provided in paragraph e) of that Article 6, to the extent that it provides: e) The processing is necessary for the performance of functions carried out in the public interest or in the exercise of the public authority vested in the data controller;

****Responsible for Processing.****

45. Contrary to what is provided in paragraph c), in this case, the basis will not result from specific legal obligations that apply to the data controller, but rather rests on a cause/authorization necessary for the fulfillment of certain assignments or competencies assigned by law to a certain entity, with a view to pursuing tasks of public interest and public powers in which it is invested, and must, in return, clearly identify the public interest at stake and the specific public authority that provides the basis, as well as the pursuits that this seeks to serve with such processing.

46. Here too, the GDPR maintains the requirement that the basis be defined by Union law or by the law of the Member State, but goes further, as a counterpoint to the broader authorization: “with respect to the processing referred to in paragraph 1, point e), it must be necessary for the exercise of functions of public interest or for the exercise of the public authority vested in the data controller.”

7 See, for example, the obligation of certain institutions to report suspicious transactions under anti-money laundering legislation, or compliance with labor law standards by employers.

8 This could only be based on the conception that we are all, in some way, recipients of legal obligations, to a greater or lesser extent, which would completely dilute the utility and effectiveness of the basis in the hermeneutics of personal data protection.

****4v.****

PAR/2025/25

47. This basis must also, impressively, “(...) provide specific provisions to adapt the application of the rules of this regulation, namely: the general conditions for the lawfulness of processing by the data controller; the types of data subject to processing; the data subjects in question; the entities to which personal data may be communicated and for what purposes; the limits to which the purposes of processing must comply; the retention periods; and the operations and procedures of processing, including measures intended to ensure the legality and fairness of processing, such as measures relating to other specific situations of processing in accordance with Chapter IX. The law of the Union or of the Member State must respond to a public interest objective and be proportional to the legitimate

objective pursued.”

48. From what can be inferred from the proposal, such elements also seem to be omitted.

49. From the institutional framework of cybersecurity and its respective assignments, it seems to be stated in the Proposal, also, the acceptance particularly in the basis just analyzed, but this important point should be clarified in contrast to what was left above regarding the other basis also invoked, since, as attempted to demonstrate, they are not interchangeable and entail distinct configurations.

50. Indeed, as stated, not only is the basis for processing crucial to assess lawful processing, but it also requires the specific regime that must be practiced and, even, specific cuts regarding the rights of data subjects (see, in this regard, what is prescribed in Article 21, under the heading right to object).

51. It also results from this that there seems to be confusion between what is stated in number 1 of Article 10 of the Project and its number 2, where it is stated that “2 - The entities that make up the institutional framework of cybersecurity may also process personal data to pursue a legitimate interest of essential and important entities, as referred to in point f), paragraph 1 of Article 6 of the GDPR.”

52. On this point, although the Portuguese translation of the GDPR of this provision may be less fortunate, Article 6, paragraph 1 in fine does not allow for significant interpretative difficulties, ruling out this solution when faced with data processing carried out by public authorities in the pursuit of their assignments and competencies, directing it only to data controllers in the private sector: “Point (f) of the first subparagraph shall not apply to processing carried out by public authorities in the performance of their tasks.”

1

PAR/2025/25

53. Paragraph 3 of the same article further prescribes that “Without prejudice to the provisions of Article 29 of Law No. 58/2019, of August 8, the entities that make up the institutional framework of cybersecurity may proceed with the processing of special categories of personal data to the extent strictly necessary: a) To prevent the occurrence of a significant cyber threat to the security of networks and information systems; b) To effectively respond to a cybersecurity incident.”

54. Notwithstanding the reference to the regime provided in Law No. 58/2019 regarding “Processing of health data and genetic data,” this clause aims to establish a generic permission for the processing of special categories of data by the entities that make up the institutional framework of cybersecurity, thus filling those categories of data subject to special protection by the European legislator, included in Article 9 of the GDPR.

55. It should be kept in mind that the processing of such data is, in principle, prohibited, and may only be carried out within the limited set of exceptions provided in paragraphs 2 and 3 of that article.

56. From this it follows that “1 - The processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, as well as the processing of genetic data, biometric data for identifying a...

person unequivocally, data related to health or data related to the sexual life or sexual orientation of a person.

57. From the Proposal under analysis, it is immediately unclear which special categories of data the Legislator intends to refer to. While it is true that the aforementioned reference to Law No. 58/2018 pertains to provisions regarding health or genetic data, the prohibition or restriction by the European Legislator is broader and, considering the requirements of proportionality or practical concordance to be carried out concretely and based on the purposes, these categories are not identical either. It may be deemed, for example, and in the abstract, that there is a need for some or any of these categories, and not necessarily others.

58. In conclusion, if data processing generally requires determining which data to process, to be assessed strictly in light of the purposes for which they are useful, only then can a restriction on their fundamental subjectivity be admitted; by greater reason, these requirements and judgments should be even more demanding when dealing with specially protected data that, by their nature, will require additional care.

59. Furthermore, as already noted, they can only be processed when they fall within one of the exhaustive circumstances provided for in numbers 2 and 3 of that legislative section.

60. Considering the reasons set forth, it is not evident that one of those exceptional causes is applicable.

****5v.****

****PAR/2025/25****

61. It would be appropriate, in this regard, to leave some observations that are related, *mutatis mutandis*, to what has already been mentioned during the analysis of the lawful basis for the processing of personal data by the indicated entities, namely that provided for in Article 6, No. 1, letter e) of the GDPR.

62. Article 9, No. 2, letter g) states that an exception to the prohibition may occur “g) If the processing is necessary for reasons of substantial public interest, based on Union law or the law of a Member State, which must be proportional to the intended objective, respect the essence of the right to the protection of personal data, and provide for appropriate and specific measures that safeguard the fundamental rights and interests of the data subject;”

63. Thus, in such cases, the processing must be proportional to the intended objective, which will consist of substantial public interest, while also respecting the right to self-determination, and must always be accompanied by “appropriate and specific measures that safeguard the fundamental rights and interests of the data subjects.”

64. Even though there seems to be an overlap with the processing of personal data based on Article 6, No. 1, letter e), to the extent that the latter also regulates processing based on public interest, the addition of the adjective “substantial” is not irrelevant.

65. Given the special protection of the data covered by Article 9, only public interests considered of particular importance can fall within the scope of this norm. This indeed reflects the particular nature of the data in question, in light of the greater risks associated with their processing, whose intrusion is also reinforced in the National Constitutional Legislation.

66. It will not be sufficient, therefore, to claim that the processing of sensitive data is necessary for the exercise of public interests, or to declare its effectiveness or utility in fact – it will first be necessary to clearly delineate what the public interest at stake is, capable of substantiating a particularly important interest, and also to demonstrate, clearly and evidently, the importance and dignity of that exceptional processing, and its indispensability for the pursuit of those interests.

67. This will require, as has already been noted here, both a positive delimitation (the benefits of that processing in light of the important interest) and a negative one (the sacrificial consequences of that interest, due to its non-processing), as well as a quantitative perspective regarding the potentially affected subjects, expressing the proportionality judgment that the Legislator has made, in the specific concrete circumstances, for which it foresees concession.

68. The Legislator must also provide adequate measures to safeguard the fundamental rights and interests of the data subjects, to be assessed concretely, defining their set of rights, whether in terms of information or in terms of guaranteeing their exercise, as well as the control, knowledge, and dominion they must have over them, distancing any possibility of “hidden” processing.

69. In summary, as stated, the essence of the right to restrict or limit must be respected, and the ontological link between the right and its holder cannot be diluted to imperceptibility, nor can it authorize blank processing of all data belonging to them, to be chosen indefinitely and at discretion by anyone wishing to process them, as occurs in the present circumstance of not defining the categories of sensitive data to be processed – this is not the practical intent provided for in the European and national regime regarding the protection of personal data.

70. Furthermore, there will also be a specification of the regime to be adopted in these processes, paying attention to the requirements set forth in the GDPR, particularly regarding the data retention period.

71. In conclusion, it is suggested to clarify compliance with these requirements, in conjunction – in direct relation – with what has already been expounded above.

****C. REGARDING THE CONTENT OF ARTICLES 23 AND 79 OF THE PROPOSAL.****

72. Article 23 of the document in question, under the heading “Cooperation between national authorities,” states that “The CNCS, the Secretary-General of the Internal Security System, and the

national sectoral cybersecurity authorities, in the exercise of their powers and responsibilities under this decree-law, act in close cooperation with: a) The National Data Protection Commission, whenever incidents involving the violation of personal data, as defined in Article 79, are at stake;”

73. In its number 7, it was stated that “The authorities referred to in this article must respond to requests for information within 5 days from the date the information was requested, unless there is a duly justified reason.”

74. The indicated Article 79, under the title “Violation of personal data,” presents the following content: “1 - Whenever the competent cybersecurity authority obtains a reasonable degree of certainty, during a supervisory action or the imposition of an enforcement measure, that the infringement of the obligations established in Articles 27 to 29 and Articles 40 to 43 by an essential or important entity may imply a violation of personal data, as defined in Article 4, point 12, of the GDPR, which must be notified under Article 33 of the same GDPR, that authority must, without unjustified delay, inform the CNPD. 2 - In the event that the CNPD imposes a fine, under Article 58, number 2, letter i) of the GDPR and other applicable national law, the competent authority is prevented from imposing a fine as a result of the same infringement under this decree-law, without prejudice to the provisions of the following number. 3 - The competent cybersecurity authority may impose the enforcement measures provided for in Article 56, number 1, letters a) to h), on essential and important entities whose violation of the obligations arising from this decree-law results in an incident of personal data breach.”

75. In the preliminary chapter of this document, a set of considerations was included that should now be recalled, such as the fact that the matters of cybersecurity and personal data protection should present common ends, as well as the desirably harmonious applicability of their dictates in favor of those ends, reserving, for that purpose, the powers and responsibilities of the data protection control authorities intact, all as results from the Directive to be implemented.

76. In view of such objectives, the GDPR assigns a broad set of exclusive powers to the personal data protection authorities – in the Portuguese case, the CNPD – namely in its Articles 56 to 58 of the GDPR, as well as in other national legislation related to personal data protection, whether through its Enforcement Law or in individual diplomas that raise issues related to personal data.

77. One of the subjects where a particular regime is prescribed and the specific competence of this Commission is outlined is precisely related to personal data breaches – e.g., see what is provided in Articles 32 to 34 of the GDPR, and the respective sanctioning regime provided in Articles 83 and 84 of the same Diploma, as well as the provisions that fill Articles 37 to 45 of Law No. 58/2019.

78. Assuming the total reservation of this Commission's competencies regarding personal data protection, as seems to be inspired by the Directive, it is believed that the relevant harmonization regarding the duty of collaboration and the spheres of intervention of each public actor should also be clarified, under penalty of undesirable overlapping competencies or difficult dialogues that may compromise the effectiveness of the essential scope of both fields, potentially sacrificing, in the end, what is sought to be reinforced.

79. From the outset, if one considers the exegesis of Article 23 of the Proposal, it seems to address “close cooperation” with the CNPD only in cases where “personal data breaches” are at stake, which appears to constitute a reduced universe if one considers the issues that may arise in pursuing cybersecurity objectives. See, in conjunction, always judging concretely, the already addressed principles embodied in Article 5 of the GDPR, the set of rights from Articles 12 to 23, the competencies and responsibilities of this Authority, and the procedural steps to be undertaken, as well as the preventive and/or sanctioning regimes to be implemented.

80. It would be desirable to establish a concrete regime for how this cooperation should proceed, taking into account, moreover, the principles of legality and competencies of Public Entities, as well as the due process that may result therefrom and which appears as an essential element in the reference to the guarantee set of the involved actors, whether in the perspective of the acts that may be practiced or in respect for the rights of citizens.

81. Furthermore, while it is true that Article 8 of Law No. 58/2019 refers to a “duty of collaboration” – which also results from the general hermeneutics of the nature and functions of this Commission – this prerogative is directed in the opposite sense, i.e., that other Entities, public or private, must cooperate with the CNPD in pursuit of the many exclusive tasks imposed by the Law.

82. It seems that the Proposal involves a relative inversion, insofar as, although the competence regarding data breaches is recognized to the CNPD, it requires, in Article 23, number 7, that it respond to requests from cybersecurity authorities within 5 days. Moreover, if this clause is read in conjunction with what is provided in Article 79, number 1, and the duty of notification that is inherent therein, it can be concluded that there may be a contradiction, and thus, it should be clarified which entities are subject to this duty.

83. What is seemingly intended to be created is a

****New Mechanism for Communicating Personal Data Breaches****

Through the knowledge of the competent cybersecurity authority, a regime that does not appear to reproduce what is provided for in Article 33 of the GDPR, thus requiring its - also new - representation.

84. If, it should be reiterated, it is understood that a conjunction of the spheres of each of the authorities is intended, the Legislator must carefully establish what the objective and subjective regime to be undertaken in this case should be, in adjectival and substantive harmonization that belongs to the sphere of the interveners.

85. It should also be noted in this context what is prescribed in Article 79, paragraphs 2 and 3 of the Proposal: “2 - In the event that the CNPD applies a fine, under the terms of Article 58, paragraph 2, subparagraph i) of the GDPR and other applicable national law, the competent cybersecurity authority is prohibited from imposing a fine as a result of the same infringement under the terms of this decree-law, without prejudice to the provisions of the following paragraph. 3 - The competent cybersecurity authority may impose the enforcement measures provided for in Article 56, paragraph 1, subparagraphs a) to h), on essential and important entities whose violation of the obligations arising from this decree-law results in an incident of personal data breach.”

86. If the Legislator has exempted the possibility of ne bis in idem, the observations just made are also reflected here.

****PAR/2025/25****

87. That is, from the architecture forged from this article, given the explained competence of the CNPD, it does not seem avoidable that there may be simultaneous or concurrent processes, susceptible to leading to different outcomes, or that in their assessment there is no communicability or communion of facts, rather focusing on what, ultimately, may or may not constitute an autonomous decision of the Data Protection Authority, but which, in truth, may stem from different constitutive facts or diverse or even divergent procedural mechanisms – the appropriate sanctions must result from the subsumption of certain facts to norms, rationally founded; in respect of the principles derived from the equitable process, the sanctions do not constitute an “act” in itself or by itself, which allows for the justification or consumption of certain concrete facts, disconnected from the judgments and rights that underpin them.

88. In conclusion, it should be regarded as the establishment of a comprehensive legal basis where the cooperation and exchange of relevant information is foreseen, more than a relative or unilateral “duty of cooperation,” even more so if one shares the idea that, in these matters, the protection of personal data may intervene more broadly than cases of data breaches.

89. Furthermore, the cybersecurity authority seems to reserve for itself, still, the possibility of imposing the enforcement measures provided for in Article 56, paragraph 1, subparagraphs a) to h) of the Proposal, which states: “a) Warnings about infringements of the duties arising from this decree-law and the respective applicable regulatory regime; b) Binding orders or instructions aimed at adopting necessary measures to prevent, impede, or correct an incident, determining the deadlines for their

execution and respective information; c) Binding orders or instructions aimed at correcting deficiencies or infringements of this decree-law; d) Binding orders or instructions aimed at compliance with the provisions of Article 26 and following or, when it concerns a public entity, the provisions of Article 33, or also aimed at compliance with the provisions of Articles 40 and following; e) Orders for the entities involved to inform the individuals or legal entities to whom they provide services or that carry out activities potentially affected by significant cyber threats of the nature of this, as well as any protective or corrective measures that may be adopted in response to that cyber threat; f) Orders for the entity in question to apply, within a reasonable time, the recommendations formulated as a result of a security audit; g) Designation of a supervisor with adequately circumscribed functions, for a limited period, to supervise compliance with the obligations provided for in Articles 26 and following, and provided for in Articles 40 and following, by the entity in question; h) Orders for the entity in question to publicize the aspects of the infringements of this decree-law in a specific manner;"

90. With this, it is also meant that some of the elements contained therein constitute not only competencies that this Commission may have in the scope of personal data breaches, but also elements that...

PAR/2025/25

may be decisive in considering whether or not to impose a fine on a certain agent, since data violations are also based on a broad concept of violation of security rules and the measures that may or may not have been implemented by the responsible party in the context of personal data protection.

91. 1. In conclusion, this Commission also believes that these aspects should be reconsidered from a systematic perspective, and that inter-institutional and organic-processual coordination capable of putting the legislative intent into practice should be clarified, which reinforces what has been said regarding the proximity of different actions and disciplines, which imposes, conversely, increased care.

D. ON THE ABSENCE OF AN IMPACT STUDY ON PERSONAL DATA PROTECTION

92. Finally, it should be emphasized that the Proposal under consideration is not supported by an impact study on personal data protection, which is, it should be noted, mandatory under the combined terms of Article 18, paragraph 4, of Law No. 43/2004, and Article 7 of Law No. 58/2019.

93. Such omission also compromises a secure and well-founded assessment regarding the probable risks arising from the processing of personal data to be carried out and, above all, may hinder the reasoned decision of the holders of political-legislative power on a matter where understanding such risks is essential to conclude, in normative-material terms, regarding the specific admissibility and conditions for the execution of data processing, especially in this area of cybersecurity, an assessment that will also be susceptible to being framed, through another avenue and in light of this nature, in the potential need for an impact assessment provided for in Article 35 of the GDPR.

III. CONCLUSION

94. In terms and with the grounds set forth, the CNPD recommends:

- a) Reassess the grounds for lawfulness established in Article 10 of the Proposal, considering the content of points 32 to 47 of this document, consequently establishing the specific regime that this imposes, as noted in points 20 to 31;
- b) Therefore, eliminate the emphasis regarding the ground for lawful processing based on "legitimate interest," as outlined in points 48 and 49;
- c) Rethink and/or deepen, in relation to a) and under penalty of unlawfulness, the processing of "special categories of data," as indicated in points 50 to 68;

8v.

PAR/2025/25

d) Establish a specific regime for legislative, procedural, and cooperation harmonization between the cybersecurity authority and the CNPD, based on their natures, attributions, and competencies, as analyzed in title "C";

e) The carrying out of an impact assessment on personal data, either through the obligation provided for in the combined terms of Article 18, paragraph 4 of Law 43/2004, Article 7 of Law 58/2019, and, given the nature of the matter at hand, under the terms of Article 35 of the GDPR.

Lisbon, March 14, 2025

Signed by: JOSÉ CARLOS VEGAR ALVES VELHO

Date: 2025.03.14 14:49:02+00'00'

José Vegar Velho (Member)